

GUÍA METODOLÓGICA PARA APLICACIÓN Y ANÁLISIS DE ENCUESTA DE CIBERSEGURIDAD

Protocolo Integral de Administración, Interpretación y Reporte

Versión: 1.0 | **Fecha:** Enero 2026

Destinatarios: Consultores, auditores internos, líderes de ciberseguridad

Complejidad: Nivel Profesional Avanzado

PARTE I: PREPARACIÓN Y ADMINISTRACIÓN DE LA ENCUESTA

1.1 Fase Pre-Encuesta: Planificación y Selección de Respondientes

Paso 1: Identificación de Stakeholders Clave

La encuesta debe ser administrada a múltiples perspectivas organizacionales para capturar visión holística:

Respondientes Mandatorios (Cuotas Mínimas):

1. Chief Information Security Officer (CISO) o equivalente (1 persona)

2. Perspectiva estratégica, gobernanza

3.

Validador principal de madurez global

4.

Head of Risk Management o responsable compliance (1 persona)

5. Perspectiva governance, regulatory alignment

6.

Validador frameworks normativos

7.

Head of IT Infrastructure / Chief Technology Officer (1 persona)

8. Perspectiva operacional, implementación técnica

9.

Validador viabilidad técnica claims

10.

Responsable Gestión de Vulnerabilidades (1 persona)

11. Perspectiva táctica vulnerabilities, scanning, remediation

12.

Validador SIEM, pen testing, VM metrics

13.

Responsable Capacitación / Recursos Humanos Seguridad (1 persona)

14. Perspectiva awareness, engagement, compliance training

15. Validador KPIs educativas

Validador principal de madurez global

Head of Risk Management o responsable compliance (1 persona)

Validador frameworks normativos

Head of IT Infrastructure / Chief Technology Officer (1 persona)

Validador viabilidad técnica claims

Responsable Gestión de Vulnerabilidades (1 persona)

Validador SIEM, pen testing, VM metrics

Responsable Capacitación / Recursos Humanos Seguridad (1 persona)

Respondientes Opcionales (Añaden Profundidad):

- Head of Incident Response
- Chief Architect (Cloud/Infrastructure)
- DevSecOps Lead
- Responsable Cumplimiento (GDPR, NIS2, compliance sector-específica)

Paso 2: Comunicación y Contexto

Comunicación Previa (2 semanas antes administración):

Enviar email formal a stakeholders:

Asunto: Administración Encuesta Evaluación Madurez Ciberseguridad Organizacional

Estimados [Nombres],

Les comunicamos que nuestro equipo procederá a administrar Encuesta Integral de Evaluación de Ciberseguridad, diseñada para mapear el estado actual de nuestro programa de seguridad contra frameworks internacionales (NIST, ISO 27001, C2M2, etc.).

OBJETIVO: Identificar fortalezas, brechas y oportunidades de mejora estratégica en gobernanza, gestión vulnerabilidades, SIEM, capacitación y respuesta a incidentes.

PARTICIPANTES: Ustedes como líderes funcionales serán solicitados responder la encuesta (45-60 minutos). Respuestas serán confidenciales; análisis consolidado.

FECHAS: Administración [FECHAS]; Cierre [FECHA final para respuestas]

El objetivo es constructivo, no punitivo. Las respuestas son puntos de partida, no juicios finales.

Paso 3: Preparación del Entorno

Formato de Administración (elegir uno):

A. Entrevista Facilitada Directa (Recomendado para primera administración)

- Facilitador administra verbalmente; toma notas
- Duración: 60-75 minutos por respondiente
- Ventaja: Clarificación contextual real-time; validación respuestas
- Desventaja: Resource-intensive

B. Auto-administrable Online (Recomendado para follow-ups)

- Platform: LimeSurvey, Qualtrics, Google Forms enterprise
- Duración: 45-60 minutos asíncrono

- Ventaja: Escalable; timestamps; menos bias
- Desventaja: Menos contexto; posible drop-off

C. Workshop Facilitado Grupal (Recomendado para large organizations)

- Facilitador conduce discusión grupal; consenso o divergencia mapeada
- Duración: 90-120 minutos
- Ventaja: Sinergia; identificación conflictos percepción rápidamente
- Desventaja: Dinámica grupal puede sesgar

Recomendación: Combinar A + B: facilitated interviews CON líderes clave (CISO, CTO, Risk Head); auto-survey para respondientes adicionales.

PARTE II: PROTOCOLO DE PUNTUACIÓN Y ANÁLISIS

2.1 Sistema de Puntuación Estandarizado

Escala Base de Madurez (6 Niveles)

Nivel 0 - Inexistente

- └ Característica: No existe proceso formalizado
- └ Puntuación Cuantitativa: 0-5 puntos
- └ Interpretación: Riesgo crítico no mitigado

Nivel 1 - Inicial

- └ Característica: Proceso ad-hoc, inconsistente, no documentado
- └ Puntuación Cuantitativa: 6-20 puntos
- └ Interpretación: Riesgo alto; mejora urgente necesaria

Nivel 2 - Repetible / Gestionable

- └ Característica: Proceso documentado; ejecución inconsistente
- └ Puntuación Cuantitativa: 21-40 puntos
- └ Interpretación: Riesgo medio; fundación existe; escalamiento requerido

Nivel 3 - Definido

- └ Característica: Proceso formalizado; implementación consistente
- └ Puntuación Cuantitativa: 41-60 puntos
- └ Interpretación: Riesgo moderado-bajo; alineación strategic posible

Nivel 4 - Cuantitativamente Gestionado

- └ Característica: Métricas; automatización parcial; continuous improvement
- └ Puntuación Cuantitativa: 61-80 puntos
- └ Interpretación: Riesgo bajo; capability bien-establecida

Nivel 5 - Optimizado

- └ Característica: Fully automated; AI-augmented; continuous innovation
- └ Puntuación Cuantitativa: 81-100 puntos
- └ Interpretación: Riesgo residual aceptable; liderazgo industria

Conversión Respuesta → Puntuación

Para preguntas de opción múltiple (Nivel 0-5):

- Respuesta Nivel X = $X * 16.67$ puntos (redondeado)
- Nivel 0 = 0 puntos

- Nivel 1 = 17 puntos
- Nivel 2 = 33 puntos
- Nivel 3 = 50 puntos
- Nivel 4 = 67 puntos
- Nivel 5 = 83 puntos (ajustado máx 100 en macro-nivel)

Para preguntas de opciones múltiples (checkbox):

- Contar items seleccionados; mapear a nivel según scoring rules específicas
- Ejemplo: Sección 3B, Pregunta 3.2
 - 0 fuentes = Nivel 0 (0 puntos)
 - 1-2 fuentes = Nivel 1 (17 puntos)
 - 3-4 fuentes = Nivel 2 (33 puntos)
 - 5-6 fuentes = Nivel 3 (50 puntos)
 - 7-9 fuentes = Nivel 4 (67 puntos)
 - 10 fuentes = Nivel 5 (83 puntos)

Para preguntas cuantitativas (e.g., MTTR, % compliance):

- Mapear rango numérico a nivel basado scoring table
- Ejemplo: MTTR Pregunta 2.6
 - >180 días = Nivel 0 (0 puntos)
 - 90-180 días = Nivel 1 (17 puntos)
 - 30-90 días = Nivel 2 (33 puntos)
 - 15-30 días = Nivel 3 (50 puntos)
 - 5-15 días = Nivel 4 (67 puntos)
 - <5 días = Nivel 5 (83 puntos)

2.2 Agregación de Puntuaciones por Módulo

Cálculo Promedio por Módulo

Fórmula:

$$\text{Puntuación Módulo} = (\text{Suma Puntuaciones Preguntas Válidas}) / (\# \text{ Preguntas Respondidas})$$

Ejemplo Cálculo Módulo 2 (Vulnerabilities & Pen Testing):

- Pregunta 2.1: Nivel 3 = 50 puntos
- Pregunta 2.2: 80% remediation = Nivel 4 = 67 puntos
- Pregunta 2.3: Integración parcial = Nivel 2 = 33 puntos
- Pregunta 2.4: Trimestral = Nivel 3 = 50 puntos
- Pregunta 2.5: Customized framework = Nivel 3 = 50 puntos
- Pregunta 2.6: 20 días MTTR = Nivel 3 = 50 puntos
- Pregunta 2.7: Sí, integrado en workflow = Nivel 4 = 67 puntos
- Pregunta 2.8: 75% coverage = Nivel 3 = 50 puntos
- Pregunta 2.9: 6 áreas scope = Nivel 3 = 50 puntos

Módulo 2 Score = (50+67+33+50+50+50+67+50+50) / 9 = 51.9 puntos (Nivel 3)

Ponderación Diferenciada (Opcional pero Recomendado)

Para organizaciones con contexto específico, aplicar pesos según criticidad:

Ejemplo Pesos Recomendados:

Módulo	Peso Normal	Peso Alt-Crítica *	Justificación
1. Gobernanza	15%	20%	Strategic leadership enables all else
2. Vulnerabilidades	20%	25%	Crítico para reduction attack surface
3. SIEM	15%	10%	Detection importante pero no foundational
4. Acceso/Identidad	15%	15%	Zero-trust prerequisite
5. Capacitación	15%	15%	Human factor critical
6. Respuesta Incidentes	12%	10%	Post-incident (vs pre-incident defense)
7. Integración Estratégica	8%	5%	Suma de partes

*Alt-Crítica = Organizaciones que han sufrido brecha reciente

Cálculo Puntuación Global Ponderada:

Score Global = (Módulo1 × Peso1) + (Módulo2 × Peso2) + ... + (Módulo7 × Peso7)

Ejemplo con pesos normales:

Score Global = (70×0.15) + (52×0.20) + (45×0.15) + (60×0.15) + (58×0.15) + (40×0.12) + (55×0.08)
 = 10.5 + 10.4 + 6.75 + 9 + 8.7 + 4.8 + 4.4
 = 54.55 puntos
 = Nivel 3 (Definido)

2.3 Análisis Comparativo y Benchmarking

Comparación vs Benchmark Industria

Referenciar resultados contra benchmarks disponibles:

Benchmarks Externos Reconocidos:

Benchmark	Industria	Tamaño Org	Score Promedio	Percentil Top 25%
Cisco 2024 Readiness	General	Enterprise	2.1/5 (42%)	3.5/5 (70%)
SANS C2M2	Energy/Critical Inf	500+	2.8/5 (56%)	3.8/5 (76%)
Verizon DBIR	General	All	2.2/5 (44%)	3.2/5 (64%)
PCI DSS Compliance	Payments	All	3.0/5 (60%)	4.0/5 (80%)

Interpretación Comparativa:

- Si Score Global 54.55 (Nivel 3 = 54.55%):
- Vs General Benchmark (42%): Organización +12.55pp arriba promedio – Fortaleza relativa
- Vs Cisco Top 25% (70%): Organización -15.45pp debajo top performers – Oportunidad mejora clara

Análisis de Divergencia: Percepción vs Realidad

Matriz de Validación Cruzada:

Respondiente	Módulo 2 Score	Módulo 3 Score	Divergencia	Interpretación
CISO	65	45	-20	CISO optimista sobre VM; pesimista SIEM
CTO	48	52	+4	CTO slightly optimistic SIEM vs VM reality
Risk Head	52	48	-4	Risk Head aligned perception

Aplicación: Si divergencias >15 puntos entre respondientes – facilitar discusión clarificadora para identificar gaps de percepción vs realidad operacional.

PARTE III: ANÁLISIS CUALITATIVO Y NARRATIVE

3.1 Análisis de Texto Libre (Preguntas 7.4 y 7.5)

Categorización de Gaps Identificados (Pregunta 7.4)

Codificación Temática:

Revisar tres gaps por respondiente; categorizar en temas comunes:

Categorías Típicas Emergentes:

1. **Gobernanza/Liderazgo** (e.g., "CISO sin autoridad suficiente", "Sin estrategia clara")
2. **Recursos Financieros** (e.g., "Presupuesto insuficiente", "ROI no justificado")

3. **Talento/Capacidades** (e.g., "Escasez especialistas", "Alta rotación")
4. **Tecnología/Tooling** (e.g., "SIEM desactualizado", "Falta integración API")
5. **Procesos/Procedimientos** (e.g., "Workflow remediation lento", "Falta playbooks")
6. **Conciencia/Comportamiento** (e.g., "Entrenamiento inefectivo", "Compliance checkbox")

Frecuencia Tabulación:

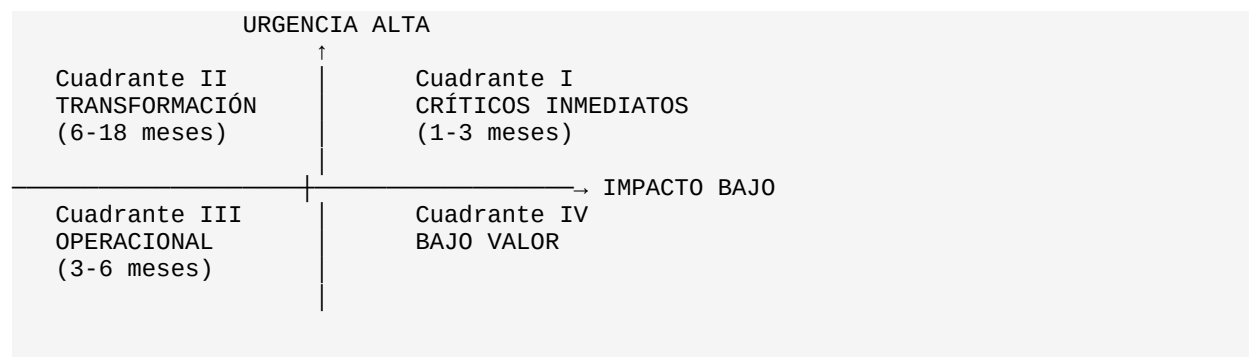
Categoría	Freq	%	Prioridad Sugerida
Recursos Financieros	5	42%	ALTA
Gobernanza	4	33%	ALTA
Talento	3	25%	MEDIA
Conciencia	2	17%	MEDIA
Procesos	2	17%	MEDIA
Tecnología	1	8%	BAJA

Interpretación: Gaps financieros y gobernanza dominantes → presupuestación y liderazgo son puntos de partida transformación.

Priorización de Iniciativas (Pregunta 7.5)

Matrix Impacto-Urgencia:

Mapear tres prioridades de cada respondiente a matrix 2x2:



Ejemplo Mapeo:

Iniciativa	Urgencia	Impacto	Cuadrante	Timeline
SIEM modernización	Alta	Alta	I	1-3 meses
MFA universal	Alta	Alto	I	2-4 meses
Threat hunting program	Media	Alto	II	6-12 meses
Awareness redesign	Media	Media	III	3-6 meses
Red team capability	Baja	Alta	II	12-18 meses

PARTE IV: GENERACIÓN DE REPORTE EJECUTIVO

4.1 Estructura Reporte Estándar

Secciones Mandatorias:

1. Executive Summary (1-2 páginas)

Contenido:

- Propósito encuesta y metodología
- Score Global actual vs benchmark industria
- Top 3 fortalezas identificadas
- Top 3 oportunidades de mejora
- Recomendación estratégica inmediata (1 párrafo)

Ejemplo:

CYBERSECURITY MATURITY ASSESSMENT - EXECUTIVE SUMMARY

This organization achieved a Global Maturity Score of 54.55/100 (Level 3: Defined), placing it 12.55 percentage points above general industry average (42%) but 15.45 points below top-quartile performers (70%). Assessment methodology included 5 senior stakeholders across governance, risk, infrastructure, vulnerabilities, and awareness functions.

TOP STRENGTHS:

1. Governance & Leadership (Nivel 4, 67 puntos): CISO authority established; board engagement present
2. Identity & Access Management (Nivel 3, 50 puntos): MFA implemented across critical systems; PAM program initiate
3. Incident Response Capability (Nivel 3, 50 puntos): IRP documented; semiannual testing completed

TOP IMPROVEMENT OPPORTUNITIES:

1. Vulnerability Management (Nivel 2, 33 puntos): Scanning regular pero remediation SLAs not consistently met; MTTR 30-90 days vs. industry best practice <5 days
2. SIEM Maturity (Nivel 2, 45 puntos): Deploye pero false positive rate >30%; threat hunting non-existent
3. Security Awareness Training (Nivel 2, 40 puntos): Annual only; phishing simulation click-rate 28% vs. target <15%

STRATEGIC RECOMMENDATION:

Execute 18-month Remediation Roadmap focusing on (1) Establish baseline SIEM tuning reducing false positives 30%-15%, (2) Implement continuous vulnerability scanning + risk-based prioritization reducing MTTR to <15 days, (3) Launch behavior-driven awareness program targeting phishing reporting rate >70%. Estimated investment: €450K Year 1; ROI: 40% incident reduction baseline.

2. Detailed Findings by Module (5-8 páginas)

Para cada módulo:

- Score actual vs. benchmark
- Análisis fortalezas/oportunidades específicas
- Recomendaciones tácticas
- Timeline estimado implementación

Ejemplo Módulo 2 (Vulnerabilities):

MODULE 2: VULNERABILITY MANAGEMENT & PENETRATION TESTING

Current Maturity Score: 51.9/100 (Level 3: Defined)

Benchmark Comparison: Industry average 48/100 (slight advantage +3.9pp)

ASSESSMENT FINDINGS:

1. Scanning Capability (Score 50 - Nivel 3)

Current State: Quarterly vulnerability scans conducted; CVSS scoring applied

Assessment: Adequate for compliance but below security best practice. Quarterly cadence creates 90-day windows of unmonitored vulnerability introduction (e.g., new component integration, library updates).

Recommendation: Upgrade to continuous scanning

- Timeline: 2-3 months implementation

- Investment: €80K (tool + staffing)

- Expected Benefit: 85% faster vulnerability discovery; MTTR reduction 30-90 days → 15-30 days

2. Penetration Testing (Score 50 - Nivel 3)

Current State: Quarterly targeted tests; MITRE ATT&CK tactical framework emerging

Assessment: Aligned with industry practice but lacks strategic red teaming. Limited chaining of vulnerabilities to demonstrate business impact.

Recommendation: Establish continuous red team capability

- Timeline: 6-9 months (hire or outsource)

- Investment: €200K annually (internal team or vendor)

- Expected Benefit: Identify complex attack chains; enable automated response validation

3. Remediation Velocity (Score 50 - Nivel 3, MTTR 20 días)

Current State: 20-day average MTTR for critical vulnerabilities

Assessment: Industry median ~30 days (better than average) but mature organizations achieve <5 days. Automation gaps likely; workflow friction between discovery and patching.

Recommendation: Implement automated patch orchestration

- Timeline: 3-4 months

- Investment: €120K (tool automation)

- Expected Benefit: MTTR reduction 20 days → 5-7 days; 65-75% faster closure

3. Risk Register Derivado (Tabla)

Risk Category	Current Control Maturity	Residual Risk Level	Mitigation Priority
Unpatched Vulnerabilities	Defined (L3)	MEDIUM	HIGH
Delayed Incident Detection	Managed (L2)	MEDIUM-HIGH	HIGH
Inadequate Phishing Resistance	Managed (L2)	HIGH	MEDIUM
Supply Chain AI Risks	Initial (L1)	CRITICAL	CRITICAL
Ransomware Resilience	Defined (L3)	MEDIUM	HIGH

4. Roadmap 18-Meses (Gantt Chart Conceptual)

	Q1 2026	Q2 2026	Q3 2026	Q4 2026	Q1 2027	Q2 2027	
SIEM Tuning (False Positives)	█						Complete Q2
Continuous Scanning Deployment	█						Complete Q2
Automated Patch Orchestration		█	█	█			Complete Q3
Threat Hunting Program Establish			█	█	█		Complete Q3
Awareness Redesign & Gamification				█	█	█	Complete Q4
Red Team Continuous Ops					█	█	Ongoing
Risk-Based Vulnerability Prio						█	Optimize Q2 2027

5. Budget Recomendado y ROI Proyectado

Año 1 Inversión (€):

Categoría	Capital	Operating	Total
SIEM Enhancement	€80K	€15K	€95K
Continuous Scanning	€60K	€25K	€85K
Automated Patching	€120K	€30K	€150K
Threat Hunting	€0	€200K	€200K
Awareness Program	€30K	€50K	€80K
Staffing (1 FTE)	€0	€75K	€75K
TOTAL YEAR 1	€290K	€395K	€685K

ROI Proyectado:

- Baseline incident cost: €500K (average large breach)
- Projected incident reduction: 40% (via enhanced detection, faster MTTR)
- Expected value saving: €200K annually
- 3-year cumulative savings: €600K - €1.2M
- **ROI Year 1:** -€85K (investment year)
- **ROI Year 2-3:** +€200K/año cada año

Break-even: 18 meses (summer 2027)

PARTE V: PRESENTACIÓN DE RESULTADOS A STAKEHOLDERS

5.1 Sesiones de Feedback Stakeholder

Formato Recomendado:

16. Presentación Ejecutiva (30 minutos, C-level)
17. Facilitador: CISO + Assessment Lead
18. Audiencia: CEO, CFO, Board representative
19.
Focus: Strategic implications, budget needs, 3-year roadmap
20.
Discusiones Funcionales (45 minutos cada, por módulo)
21. Facilitador: Assessment Lead + Functional Owner
22. Audiencia: Module respondents + peer leaders
23.
Focus: Validation findings, barriers identification, tactical planning
24.
Workshop Integración (90 minutos, full leadership)
25. Facilitador: CISO + Assessment Lead
26. Audiencia: All respondents + key stakeholders
27. Focus: Alignment roadmap, dependencies, resource allocation

Focus: Strategic implications, budget needs, 3-year roadmap

Discusiones Funcionales (45 minutos cada, por módulo)

Focus: Validation findings, barriers identification, tactical planning

Workshop Integración (90 minutos, full leadership)

5.2 Plan de Comunicación Interna

Semana 1 Post-Assessment:

- Enviar draft findings a CISO para validation
- Incorporar comentarios

Semana 2:

- Presentación ejecutiva a C-level
- Discusión presupuesto y recursos

Semana 3:

- Sesiones funcionales por módulo
- Validación hallazgos técnicos

Semana 4:

- Workshop integración
- Consensus roadmap

Semana 5:

- Comunicación toda organización (appropriate level)
- Transparencia genera buy-in

FIN GUÍA METODOLÓGICA